

W12D1

Vulnerability Assessment

Parte I — Report tecnico

Sommario

Questo documento riporta i risultati di un Vulnerability Assessment condotto con Nessus sulla macchina bersaglio Metasploitable (192.168.50.101), limitatamente alle porte comuni. La scansione è stata eseguita tramite Basic Network Scan e ha rilevato complessivamente 69 vulnerabilità, la maggior parte delle quali di tipo informativo, ma con alcune criticità gravi: un sistema operativo fuori supporto, una backdoor con shell di root, un accesso VNC protetto da password banale, protocolli SSL/TLS obsoleti e diversi servizi che trasmettono dati in chiaro. Il report descrive, per ciascuna vulnerabilità significativa, il servizio interessato, la relativa remediation (come intervenire) e il riferimento alla CVE con link al National Vulnerability Database (NVD). Include inoltre un'analisi di come ciascuna vulnerabilità principale verrebbe sfruttata.

1. Panoramica dei risultati

La distribuzione per gravità conferma il profilo tipico di una macchina volutamente vulnerabile:

Distribuzione delle vulnerabilità per gravità

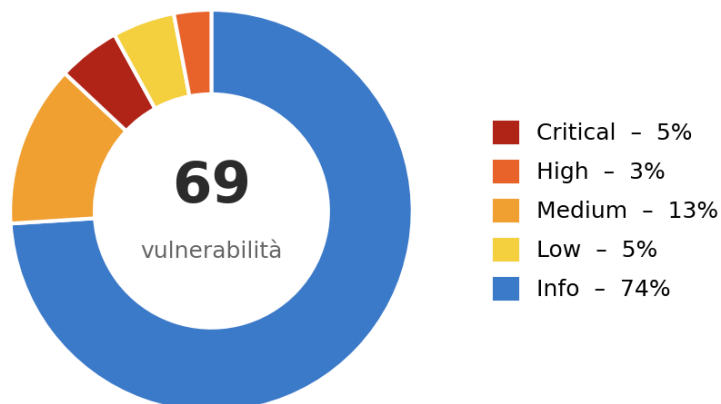


Figura 1 — Distribuzione delle 69 vulnerabilità per livello di gravità.

2. Vulnerabilità critiche

- Canonical Ubuntu Linux SEoL (8.04.x) [CRITICAL – CVSS 10.0]

Porta/servizio: 80/tcp — sistema operativo

Descrizione. Il sistema operativo del bersaglio è Ubuntu 8.04 “Hardy”, giunto a fine supporto (Security End of Life) il 9 maggio 2013. Da oltre dieci anni non riceve più patch di sicurezza: qualunque vulnerabilità scoperta nel frattempo è quindi priva di correzione.

Remediation. Aggiornare il sistema a una versione di Ubuntu attualmente supportata (testo Nessus: “Upgrade to a version of Canonical Ubuntu Linux that is currently supported”).

Riferimento: Fine supporto vendor (<https://wiki.ubuntu.com/Releases>). CPE: `cpe:/o:canonical:ubuntu_linux`

▪ VNC Server 'password' Password [CRITICAL – CVSS 10.0 (CVSS v2)]

Porta/servizio: 5900/tcp — VNC

Descrizione. Il server VNC sull’host remoto è protetto da una password debole. Nessus è riuscito ad autenticarsi tramite VNC usando la password “password”. Un attaccante remoto non autenticato può sfruttarlo per prendere il controllo del sistema. (Output Nessus: “Nessus logged in using a password of password”).

Remediation. Proteggere il servizio VNC con una password robusta. Se l’accesso grafico remoto non serve, disabilitare il servizio.

Come si sfrutta. Un attaccante si collega con un client VNC — ad esempio vncviewer 192.168.50.101:5900 — e inserisce la password “password”; in Metasploit il modulo auxiliary/scanner/vnc/vnc_login individua la credenziale.

Risultato per l’attaccante. Sessione grafica remota completa, come se l’attaccante fosse davanti allo schermo.

Riferimento: <https://nvd.nist.gov/vuln/detail/cve-1999-0506>

Metasploitable / Plugin #61708
← Back to Vulnerabilities

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 69 Remediations 2 Notes 3 History 1

CRITICAL VNC Server 'password' Password

Description
The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution
Secure the VNC service with a strong password.

Output
Nessus logged in using a password of "password".
To see debug logs, please visit individual host

Port **Hosts**
5900/tcp/vnc 192.168.50.101

Plugin Details

Severity: Critical
ID: 61708
Version: 1.2.5
Type: remote
Family: Gain a shell remotely
Published: August 29, 2012
Modified: September 26, 2015

Risk Information
Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/C/C/A:C

Vulnerability Information

Figura 2 — Nessus: accesso VNC riuscito con la password “password” (porta 5900).

▪ Bind Shell Backdoor Detection [CRITICAL – CVSS 9.8]

Porta/servizio: 1524/tcp

Descrizione. Una shell è in ascolto sulla porta remota senza richiedere alcuna autenticazione: un attaccante può usarla connettendosi alla porta e inviando comandi direttamente. Nessus ha dimostrato lo sfruttamento eseguendo il comando “id” e ottenendo privilegi di root (uid=0(root)). È una backdoor.

Come si sfrutta. La backdoor non richiede autenticazione: basta collegarsi alla porta con netcat (nc 192.168.50.101 1524) per ottenere subito una shell.

Risultato per l’attaccante. Shell di root immediata (uid=0), controllo totale del sistema

Remediation. Verificare se l’host è stato compromesso e reinstallare il sistema. Chiudere la porta non basta se il sistema è già compromesso.

Riferimento: Plugin 51988 — backdoor intenzionale di Metasploitable (nessuna CVE formale).

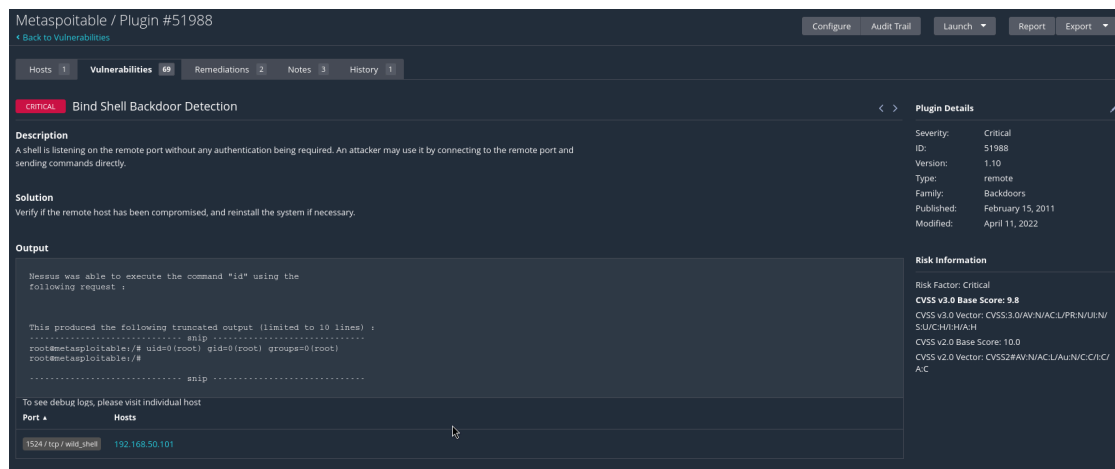


Figura 3 — Nessus: esecuzione del comando “id” con output uid=0(root) sulla porta 1524.

▪ SSL Version 2 and 3 Protocol Detection [CRITICAL – CVSS 9.8]

Porta/servizio: 25/tcp (SMTP), 5432/tcp (PostgreSQL)

Descrizione. Il servizio remoto accetta connessioni cifrate con SSL 2.0 e SSL 3.0. Queste versioni sono affette da debolezze crittografiche. Un attaccante può sfruttarle per attacchi man-in-the-middle o per decifrare le comunicazioni. NIST e PCI DSS non considerano più SSL una crittografia robusta.

Come si sfrutta. È un attacco crittografico, non una shell: da una posizione man-in-the-middle, POODLE (SSLv3) e DROWN (SSLv2) permettono di forzare l'uso dei protocolli deboli e decifrare porzioni del traffico cifrato.

Risultato per l'attaccante. Decifratura e intercettazione di dati che dovrebbero essere protetti.

Remediation. Disabilitare SSLv2/v3 e consentire solo TLS 1.2 o superiore.

Riferimento: nvd.nist.gov/vuln/detail/CVE-2014-3566

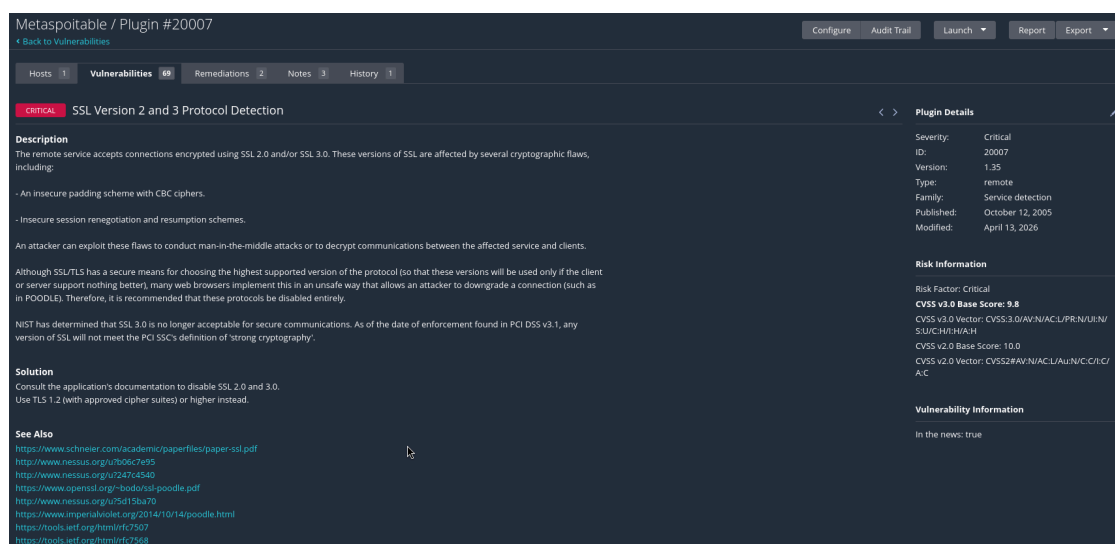


Figura 4 — Nessus: rilevamento dei protocolli SSL 2.0/3.0 (descrizione e soluzione).

▪ Debian OpenSSH/OpenSSL — Random Number Generator Weakness [CRITICAL – CVSS 10.0 (CVSS v2)]

Porta/servizio: 22/tcp (SSH), 25/tcp (SMTP), 5432/tcp (PostgreSQL)

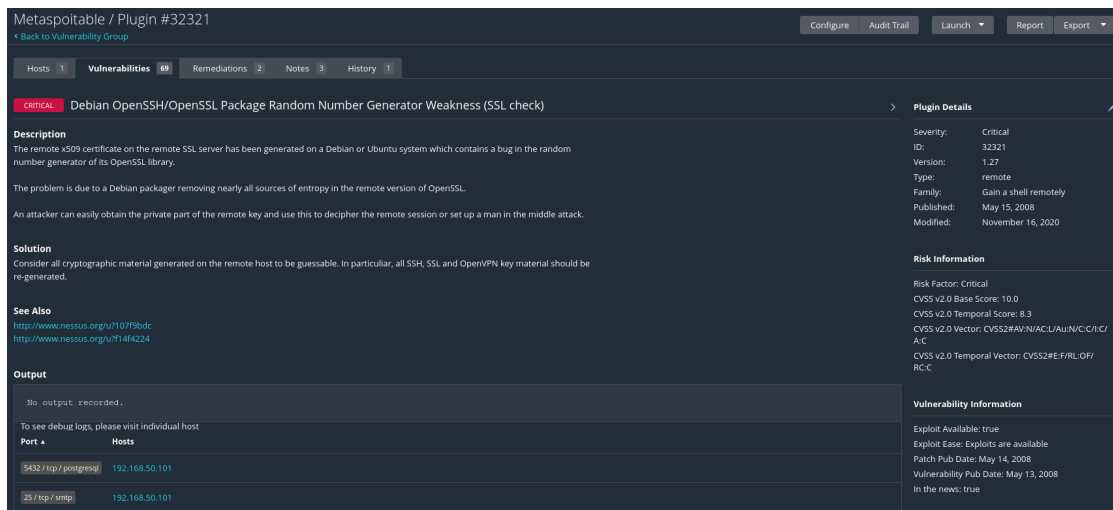
Descrizione. Il materiale crittografico dell'host (chiave host SSH e certificati SSL) è stato generato su un sistema Debian/Ubuntu affetto da un bug nel generatore di numeri casuali della libreria OpenSSL: un packager Debian ha reso le chiavi prevedibili. Un attaccante può ricavare facilmente la chiave privata e usarla per decifrare le sessioni o condurre attacchi man-in-the-middle.

Come si sfrutta. Le chiavi generate appartengono a un insieme ristretto e precalcolabile. L'attaccante confronta la chiave pubblica SSH del target con i set pubblici di chiavi deboli, ricava la chiave privata corrispondente e la usa per autenticarsi.

Risultato per l'attaccante. Accesso SSH all'host senza conoscere la password, usando la chiave privata ricostruita.

Remediation. Considerare prevedibile tutto il materiale crittografico generato sull'host: dopo aver aggiornato OpenSSL, rigenerare tutte le chiavi SSH, SSL e OpenVPN (testo Nessus: “all SSH, SSL and OpenVPN key material should be re-generated”).

Riferimento: nvd.nist.gov/vuln/detail/CVE-2008-0166



Metasploitable / Plugin #32321
4 Back to Vulnerability Group

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 19 Remediations 2 Notes 3 History 1

CRITICAL Debian OpenSSH/OpenSSL Package Random Number Generator Weakness (SSL check)

Description
The remote x509 certificate on the remote SSL server has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.
The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.
An attacker can easily obtain the private part of the remote key and use this to decipher the remote session or set up a man in the middle attack.

Solution
Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

See Also
<http://www.nessus.org/u/10779bdc>
<http://www.nessus.org/u/114f4224>

Output
No output recorded.
To see debug logs, please visit individual host

Port Hosts
5432/tcp/postgresql 192.168.50.101
25/tcp/smtp 192.168.50.101

Plugin Details
Severity: Critical
ID: 32321
Version: 1.27
Type: remote
Family: Gain a shell remotely
Published: May 15, 2008
Modified: November 16, 2020

Risk Information
Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Temporal Score: 8.3
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C
CVSS v2.0 Temporal Vector: CVSS2#E:F/RL:OF/RC:C

Vulnerability Information
Exploit Available: true
Exploit Ease: Exploits are available
Patch Pub Date: May 14, 2008
Vulnerability Pub Date: May 13, 2008
In the news: true

Figura 5 — Nessus: debolezza del generatore di numeri casuali OpenSSL su sistemi Debian/Ubuntu.

2. Vulnerabilità alte

■ NFS Shares World Readable [HIGH – CVSS 7.5]

Porta/servizio: 2049/tcp — NFS

Descrizione. Il servizio NFS esporta condivisioni di rete leggibili da chiunque (“world readable”), senza restrizioni sugli host autorizzati. Un attaccante sulla rete può montare le condivisioni e leggere i file esposti.

Come si sfrutta. Con showmount -e 192.168.50.101 si elencano gli export; se la radice è esportata in scrittura, l'attaccante monta la condivisione (mount -t nfs) e scrive la propria chiave pubblica in /root/.ssh/authorized_keys, poi entra via SSH. È il classico percorso NFS → root di Metasploitable.

Risultato per l'attaccante. Lettura di file sensibili e se l'export è scrivibile accesso come root.

Remediation. Restringere gli export in /etc/exports ai soli host autorizzati.

Riferimento: <https://nvd.nist.gov/vuln/detail/cve-1999-0554>

▪ **rlogin Service Detection** [HIGH – CVSS 7.5]

Porta/servizio: 513/tcp – rlogin

Descrizione. Il servizio rlogin è attivo. È un protocollo legacy che trasmette le credenziali in chiaro e si basa su un meccanismo di fiducia (file .rhosts) facilmente aggirabile.

Come si sfrutta. Se l'host accorda fiducia tramite file .rhosts permissivi, rlogin -l root 192.168.50.101 consente l'accesso senza password; in ogni caso le credenziali viaggiano in chiaro e sono intercettabili sulla rete.

Risultato per l'attaccante. Accesso remoto (anche come root) o furto delle credenziali.

Remediation. Disabilitare i servizi r-* (rlogin, rsh, rexec) e sostituirli con SSH.

Riferimento: <https://nvd.nist.gov/vuln/detail/cve-1999-0651>

▪ **Samba Badlock Vulnerability** [HIGH – CVSS 7.5]

Porta/servizio: 139/tcp, 445/tcp – Samba/SMB

Descrizione. La versione di Samba installata è affetta dalla vulnerabilità “Badlock” nei protocolli SAMR e LSAD: un attaccante in posizione di intercettazione può condurre attacchi man-in-the-middle sui canali di amministrazione e provocare condizioni di Denial of Service.

Come si sfrutta. Non fornisce una shell diretta: è un attacco man-in-the-middle sui canali di amministrazione SAMR/LSAD, che richiede una posizione di intercettazione tra client e server.

Risultato per l'attaccante. Dirottamento di sessioni amministrative o condizione di Denial of Service.

Remediation. Aggiornare Samba alla versione 4.2.11 / 4.3.8 / 4.4.2 o successive

Riferimento: nvd.nist.gov/vuln/detail/CVE-2016-2118

3. Vulnerabilità medie

- **Unencrypted Telnet Server [MEDIUM – CVSS 6.5]**

Porta/servizio: 23/tcp – Telnet

Descrizione. Il servizio Telnet trasmette l'intera sessione, credenziali comprese, in chiaro sulla rete. Chiunque intercetti il traffico può leggere username e password e prendere il controllo dell'accesso.

Come si sfrutta. Intercettando il traffico con uno sniffer (es. Wireshark) durante un login Telnet si leggono username e password in chiaro.

Risultato per l'attaccante. Furto delle credenziali e accesso al sistema.

Remediation. Disabilitare Telnet e utilizzare SSH per l'amministrazione remota.

Riferimento: <https://nvd.nist.gov/vuln/detail/cve-1999-0619>

- **TLS Version 1.0 Protocol Detection [MEDIUM – CVSS 6.5]**

Porta/servizio: servizi TLS

Descrizione. Protocollo deprecato.

Remediation. Disabilitare TLS 1.0 (e 1.1) e consentire solo TLS 1.2 o superiore.

Riferimento:

- **SSL DROWN Attack Vulnerability [MEDIUM – CVSS 5.9]**

Porta/servizio: servizi SSL

Descrizione. Il supporto residuo a SSLv2 espone all'attacco DROWN, che permette di decifrare sessioni TLS anche moderne sfruttando lo stesso certificato su un servizio che accetta SSLv2.

Remediation. Disabilitare SSLv2 su tutti i servizi che condividono chiavi/certificati e verificare che nessun servizio esponga ancora SSLv2.

Riferimento: nvd.nist.gov/vuln/detail/CVE-2016-0800

- **SSL Anonymous Cipher Suites Supported [MEDIUM – CVSS 5.9]**

Porta/servizio: servizi SSL

Descrizione. Sono accettate suite di cifratura anonime, che non autenticano il server: un attaccante può inserirsi come man-in-the-middle senza essere rilevato.

Remediation. Disabilitare i cifrari anonimi (aNULL) e NULL; consentire solo cifrari autenticati e robusti.

Riferimento: <http://www.nessus.org/u?3a040ada>

4. Vulnerabilità basse e problemi raggruppati

Le vulnerabilità di gravità bassa rilevate sono:

- **SSL/TLS Diffie-Hellman Modulus ≤ 1024 bit (Logjam) — CVSS 3.7:** parametri Diffie-Hellman deboli, attacco Logjam. Usare gruppi DH da almeno 2048 bit. Rif. CVE-2015-4000.
- **X Server Detection — CVSS 2.6:** il server grafico X11 è raggiungibile in rete. Limitarne l'accesso ai soli host locali/autorizzati.
- **ICMP Timestamp Request Remote Date Disclosure — CVSS 2.1:** il sistema rivela l'ora locale, informazione utile a un attaccante. Bloccare le richieste ICMP timestamp sul firewall.

Nessus ha inoltre raggruppato numerose rilevazioni sotto voci “Multiple Issues”, che raccolgono più problemi minori o informativi per singolo servizio:

Gruppo	Servizio	Rilevazioni
SSL (Multiple Issues)	Generale	28
SMB (Multiple Issues)	Windows/SMB	7
SSH (Multiple Issues)	SSH	6
ISC Bind (Multiple Issues)	DNS	5
HTTP (Multiple Issues)	Web	5
Apache Tomcat (Multiple Issues)	Web	4
FTP / VNC / DNS (Multiple Issues)	Vari	3 ciascuno

Questi gruppi comprendono soprattutto rilevazioni informative (fingerprinting dei servizi, versioni, certificati) e alcuni problemi di configurazione.

5. Remediation prioritarie

Nessus ha evidenziato due azioni correttive che risolvono più vulnerabilità contemporaneamente:

Azione correttiva	Vuln.
ISC BIND 9.x < 9.11.22 / 9.12.x < 9.16.6 / 9.17.x < 9.17.4 (DoS): aggiornare a BIND 9.11.22, 9.16.6, 9.17.4 o successive	3
Samba Badlock: aggiornare a Samba 4.2.11 / 4.3.8 / 4.4.2 o successive	1

In sintesi:

- 1. Isolare e reinstallare il sistema per rimuovere la backdoor sulla porta 1524.
- 2. Aggiornare il sistema operativo a una versione supportata.
- 3. Eliminare le credenziali deboli (VNC) e i servizi in chiaro (Telnet, rlogin).
- 4. Correggere la configurazione SSL/TLS (disabilitare SSLv2/v3, TLS 1.0, cifrari anonimi).
- 5. Aggiornare Samba e ISC BIND; restringere gli export NFS.

6. Conclusioni

Il bersaglio presenta un profilo di rischio molto elevato: un sistema operativo deprecato, una backdoor con shell di root, credenziali banali e servizi in chiaro, che consentono la compromissione della macchina. (In Metasploitable questo è atteso). La priorità è rimuovere la backdoor e il software non supportato, eliminare credenziali deboli e servizi in chiaro, sanare la configurazione crittografica.

Parte II — Report per dirigente

Sommario

È stata condotta una verifica di sicurezza (Vulnerability Assessment) per individuare le debolezze sfruttabili da un eventuale attaccante. La verifica ha rilevato 69 elementi, la maggior parte dei quali informativi, ma con un nucleo di problemi gravi che potrebbero esporre l'azienda alla compromissione del server e all'accesso ai dati in esso contenuti.

Il livello di rischio complessivo è valutato ALTO. Sono presenti vulnerabilità che consentirebbero a un attaccante di prendere il controllo del sistema in modo diretto e con competenze minime. Si raccomandano interventi correttivi descritti al punto 4.

1. Distribuzione del rischio

Il grafico seguente mostra come si distribuiscono i 69 elementi rilevati per livello di gravità. Le voci "Info" non rappresentano problemi di sicurezza, ma informazioni tecniche sul sistema; l'attenzione va posta sulle voci Critical, High e Medium.

Distribuzione delle vulnerabilità per gravità

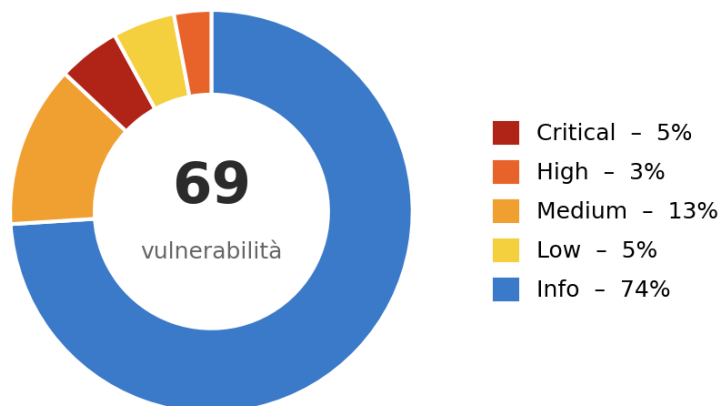


Figura 1 — Ripartizione delle vulnerabilità per gravità.

2. Le vulnerabilità più critiche

Il grafico riporta le sette vulnerabilità più gravi, ordinate per punteggio di pericolosità (scala CVSS da 0 a 10, dove 10 è il massimo).

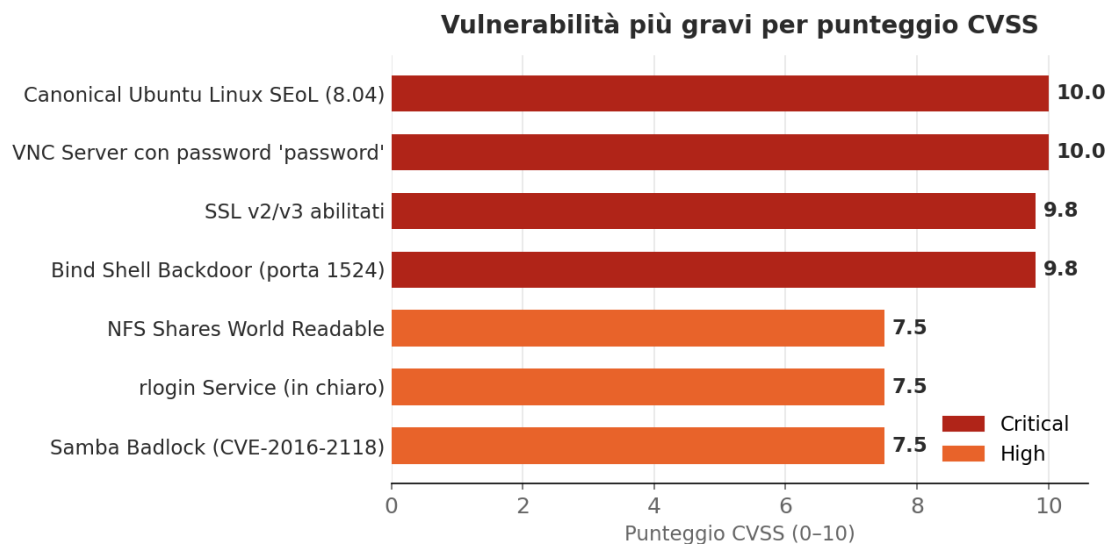


Figura 2 — Vulnerabilità più gravi per punteggio di pericolosità (CVSS).

Sintesi:

- **Sistema operativo obsoleto:** il server usa un software di base fuori supporto da oltre dieci anni, che non riceve più aggiornamenti di sicurezza.
- **“Porta di servizio” nascosta (backdoor):** esiste un accesso nascosto che consente a chiunque di comandare il server senza password.
- **Accesso remoto con password banale:** il controllo a distanza dello schermo è protetto dalla password “password”, di fatto indovinabile all’istante.
- **Comunicazioni protette in modo obsoleto:** i sistemi di cifratura usati sono superati e non garantiscono più la riservatezza dei dati.
- **Servizi che espongono dati e file:** alcuni servizi trasmettono informazioni “in chiaro” o rendono accessibili file a chiunque sulla rete.

3. Valutazione del rischio complessivo

Il sistema, così com’è, non può essere considerato sicuro. La combinazione di software non aggiornato, accessi non protetti e comunicazioni deboli può comportare il rischio di furto o perdita di dati, interruzione del servizio e utilizzo del server come punto d’appoggio per attacchi ulteriori.

4. Raccomandazioni

#	Intervento	Priorità / effort
1	Rimuovere l'accesso nascosto (backdoor): isolare e reinstallare il sistema	Immediata / medio
2	Aggiornare il sistema operativo a una versione supportata	Immediata / medio
3	Eliminare le password banali e i servizi di accesso non protetti	Alta / basso
4	Aggiornare i sistemi di cifratura delle comunicazioni	Alta / basso
5	Aggiornare i componenti software vulnerabili (Samba, servizi DNS) e limitare le condivisioni	Media / basso

5. Conclusione

La verifica ha evidenziato un rischio ALTO, dovuto principalmente a software obsoleto e ad accessi non adeguatamente protetti. Gli interventi raccomandati sono realizzabili con risorse limitate e, se attuati nell'ordine indicato, riportano il sistema a un livello di sicurezza accettabile.